DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

Cuidarte+

Informe de seguridad y calidad en el desarrollo de software

CUIDARTE+

ISY1102 · Seguridad y Calidad en el Desarrollo de Software
Ingeniería en Informática
Sección: 001V
Docente: Jose Sergio Collio Huennun
Septiembre de 2026

Integrantes
Ari Araya
Giannina Guerrero
Skarlett Tropan
Nicolás Barra

ÍNDICE

1. Introducción
2. Criterios de calidad, seguridad y cumplimiento normativo
3. Plan de pruebas
4. Diseño de casos de prueba
5. Análisis de cobertura, pertinencia y coherencia
6. Conclusiones y recomendaciones
7. Referencias

1. Introducción

1.1 Contexto del software a evaluar

Cuidarte+ es una plataforma web orientada a centros de salud, desarrollada por CreaLab Spa, cuya finalidad es la gestión de pacientes, exámenes médicos y documentos clínicos. El sistema contempla cuatro perfiles de uso: los médicos registran pacientes y exámenes médicos; los pacientes visualizan su información clínica y descargan los documentos asociados; los administradores supervisan, auditan y administran usuarios y datos; y los visitantes solo acceden al flujo de registro, sin acceso alguno a información clínica.

Arquitectónicamente, Cuidarte+ se implementa como una aplicación multicapa compuesta por un frontend React (SPA), un backend Express/Node.js que expone una API REST y una base de datos PostgreSQL. Las comunicaciones deben realizarse sobre TLS, las contraseñas deben almacenarse mediante hashing con bcrypt, la autenticación se sustenta en tokens JWT y los documentos clínicos se conservan en almacenamiento interno con su referencia en base de datos.

Dado que el sistema trata datos de carácter personal y, en particular, datos sensibles de salud —grupo sanguíneo, alergias, enfermedades crónicas, discapacidades, diagnósticos y tratamientos—, cualquier fallo de calidad, seguridad o cumplimiento normativo compromete simultáneamente la confidencialidad clínica del paciente, la continuidad operativa del centro de salud y la responsabilidad legal de la organización. Esta triple exposición es la que justifica que el presente plan no se limite a verificar funcionalidad.

1.2 Propósito del plan de pruebas

Diseñar una estrategia integral que asegure, antes de producción, que Cuidarte+ cumple los requerimientos funcionales del ERS (RF-1 a RF-5), satisface atributos no funcionales (seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad) y se alinea con el marco legal chileno de datos personales, ciberseguridad, documentos electrónicos y accesibilidad. El plan adopta el enfoque QA + Seguridad + Cumplimiento, evitando tratar la norma como una fase aislada al final.

1.3 Objetivos

Definir criterios de calidad, seguridad y cumplimiento trazables a códigos del ERS; clasificar y justificar los tipos de prueba aplicables; establecer estrategia, herramientas, criterios de entrada y salida, recursos y cronograma; diseñar al menos cinco casos representativos (CP-01 a CP-06); y evaluar cobertura, brechas y coherencia frente al ERS y al marco normativo (IE5).

1.4 Alcance

Incluye autenticación y sesión (RF-1), roles y reglas RB-1/RB-2/RB-3, exámenes y documentos (RF-3, RF-4), auditoría (RF-5) y atributos NFR-SEG, NFR-PERF, NFR-USAB y NFR-COMPAT. Quedan fuera de esta EV1 el pentest certificado, la certificación WCAG formal, la auditoría legal externa y la medición prolongada de disponibilidad 99,5%.

1.5 Estructura del informe

El documento sigue el Ítem I del encargo y la plantilla institucional: introducción; criterios y normativa; plan de pruebas (estrategia, tipos, aceptación, herramientas y recursos); diseño de casos; análisis de cobertura; conclusiones y referencias. Al final de la sección de casos se incorpora una nota técnica de ejecución exploratoria (API autenticada, OWASP ZAP y JMeter) como evidencia complementaria.

2. Criterios de calidad, seguridad y cumplimiento normativo

Los criterios que se establecen a continuación constituyen el estándar contra el cual se evaluará Cuidarte+. Se derivan de tres fuentes complementarias: el modelo de calidad ISO/IEC 25010, los requerimientos no funcionales comprometidos en el ERS y el marco legal chileno aplicable al tratamiento de datos de salud.

2.1 Criterios de calidad

Se adoptan como referencia las características del modelo ISO/IEC 25010 pertinentes al dominio, vinculando cada atributo a los códigos del ERS que lo sustentan y a la evidencia que deberá producir la ejecución de las pruebas.

Atributo	Criterio de calidad	Requerimiento ERS	Evidencia esperada
Usabilidad	Tipografía legible, contraste adecuado, controles amplios para adultos mayores y flujos de navegación claros	NFR-USAB-1 a NFR-USAB-4	Sesiones con usuarios representativos; auditoría Lighthouse
Rendimiento	Operaciones CRUD bajo 300 ms; carga de página principal bajo 2 s; soporte de 200 usuarios concurrentes	NFR-PERF-1 a NFR-PERF-3	Pruebas de carga con k6 o JMeter
Fiabilidad y disponibilidad	Disponibilidad objetivo de 99,5% mensual con ventanas de mantenimiento controladas	NFR-DIS-1, NFR-DIS-2	Monitoreo y pruebas de recuperación
Mantenibilidad	Código testeable, endpoints documentados y validación del lado del servidor	Interfaces backend, ERS §3.1.2	Cobertura de endpoints críticos; documentación Swagger
Compatibilidad	Últimas dos versiones de Chrome, Firefox, Safari y Edge; diseño responsive en móvil y tablet	NFR-COMPAT-1, NFR-COMPAT-2	Matriz de navegadores y dispositivos

2.2 Criterios de seguridad

La seguridad se trata como un requerimiento verificable y no como una cualidad declarativa. Cada criterio del ERS se traduce en una condición observable durante la ejecución de las pruebas.

ID ERS	Criterio	Qué se verifica
NFR-SEG-1	TLS obligatorio	El tráfico HTTP es rechazado o redirigido forzosamente a HTTPS
NFR-SEG-2	Hashing con bcrypt	Las contraseñas no se almacenan ni se comparan en texto plano
NFR-SEG-3	Cifrado en reposo de datos sensibles	Documentos y datos clínicos protegidos en almacenamiento y base de datos
NFR-SEG-4	Control de acceso por rol (RBAC)	El paciente no escribe; el administrador ejerce CRUD completo; el médico opera según RB-3
NFR-SEG-5	Protección frente a CSRF, XSS e inyección SQL	Entradas validadas y saneadas; cargas maliciosas rechazadas
NFR-SEG-6	Registros de auditoría seguros	Eventos relevantes registrados sin filtrar secretos ni credenciales
NFR-SEG-7	Respaldo y recuperación	Política de backup verificable y restauración probada
NFR-SEG-8	Cumplimiento normativo de datos personales	Trazabilidad, minimización y acceso restringido
NFR-SEG-9	Gestión de sesión JWT	Token de corta vigencia con cierre de sesión y revocación (RF-1.2)

Reglas de negocio asociadas

RB-1: el paciente dispone únicamente de permisos de lectura sobre su propia información.

RB-2: el administrador ejerce operaciones CRUD completas sobre usuarios y datos.

RB-3: el médico puede consultar la información clínica de cualquier paciente registrado.

2.3 Cumplimiento normativo y legal

Cuidarte+ trata datos personales y datos sensibles de salud, condición que determina el régimen jurídico aplicable y, con él, el estándar técnico exigible. La calificación no es accesoria: el propio modelo de datos del sistema registra alergias, enfermedades crónicas, discapacidades, diagnósticos y tratamientos, de modo que la organización que opere la plataforma actúa como responsable del tratamiento de datos sensibles frente a la legislación chilena.

Las normas se ordenan a continuación según su exigencia concreta sobre el sistema, indicando en cada caso la traducción operativa que reciben dentro de este plan de pruebas.

Norma o estándar	Aspecto relevante	Aplicación en Cuidarte+	Traducción a prueba
Ley 19.628, sobre protección de la vida privada	Régimen del tratamiento de datos personales y sensibles; art. 22 sobre registro y art. 23 sobre indemnización por tratamiento indebido	Finalidad declarada, deber de secreto y derechos del paciente sobre su ficha clínica	Verificación de acceso restringido por rol y de no exposición indebida de la ficha clínica
Ley 21.719, sobre protección de datos personales	Principios de licitud, finalidad, proporcionalidad, seguridad y responsabilidad proactiva; deber de notificar brechas; art. 35 con multas de hasta 5.000, 10.000 y 20.000 UTM según gravedad	La organización es responsable del tratamiento de datos clínicos y responde patrimonialmente por las infracciones	Casos de autorización, minimización de datos y registro de incidentes de acceso
Ley 21.663, Ley Marco de Ciberseguridad	Gestión de riesgos, sistema de gestión de seguridad y deber de reportar incidentes; art. 36 remite a los arts. 246, 247 y 247 bis del Código Penal y el art. 40 fija multas de hasta 20.000 UTM, o 40.000 UTM tratándose de un operador de importancia vital	La prestación de salud se considera servicio esencial, lo que eleva el estándar exigible a la plataforma	Pruebas de detección y reporte de incidentes, endurecimiento de configuración y verificación de controles
Decreto 181 de 2002 y Ley 19.799	Documento electrónico y firma electrónica; el Título Cuarto protege los derechos de los usuarios y su letra b) sobre seguridad remite expresamente a la norma NCh 27002.Of2009	Los informes de exámenes almacenados constituyen documentos electrónicos con valor clínico	Verificación de integridad, autenticidad y no repudio de los documentos almacenados
NCh 27002.Of2009	Código de práctica para la gestión de la seguridad de la información	Marco técnico de controles al que remite el Decreto 181	Lista de verificación de controles: acceso, criptografía, registros y respaldos
Ley 21.459, sobre delitos informáticos	Tipifica el acceso ilícito, la interceptación ilícita y el ataque a la integridad de datos y sistemas	Define el bien jurídico que el sistema debe proteger; cada vulnerabilidad abierta es una vía habilitante	Pruebas de acceso no autorizado, escalamiento de privilegios e inyección, con respaldo en RF-5.1
Ley 17.336, sobre propiedad intelectual	El software es obra protegida; los arts. 78 y 79 establecen las sanciones por uso no autorizado	Compatibilidad de licencias de las dependencias de terceros utilizadas en el frontend y el backend	Auditoría de licencias del árbol de dependencias (análisis de composición de software)
Manual de Accesibilidad Web	Criterios de perceptibilidad, operabilidad, comprensibilidad y	Portal del paciente, orientado a personas mayores y a usuarios con discapacidad	Verificación de contraste, tamaño de controles y navegación por teclado

Norma o estándar	Aspecto relevante	Aplicación en Cuidarte+	Traducción a prueba
	robustez, alineados con WCAG		
Política Nacional de Ciberseguridad	Instrumento programático sobre resiliencia, derechos en el ciberespacio y desarrollo seguro	Marco orientador institucional, sin efecto sancionatorio directo	Fundamenta la priorización por riesgo adoptada en la estrategia

Un caso particular merece precisión: la Ley 21.180 sobre transformación digital del Estado no resulta directamente exigible a Cuidarte+ mientras opere como prestador privado. Solo pasa a ser aplicable si el sistema interopera con organismos de la Administración del Estado, como FONASA, el Registro Civil o un servicio de salud público. Se declara aquí como criterio de interoperabilidad futura y no como obligación vigente.

2.4 Matriz criterio → requerimiento → norma

La siguiente matriz sintetiza la trazabilidad entre los criterios transversales del plan, los códigos del ERS que los materializan y la norma que les sirve de respaldo. Constituye el puente entre la exigencia jurídica y el caso de prueba ejecutable.

Criterio transversal	Códigos ERS	Norma o estándar de respaldo
Confidencialidad clínica	NFR-SEG-3, NFR-SEG-4, RB-1	Ley 19.628; Ley 21.719
Autenticación robusta	RF-1.1, RF-1.2, NFR-SEG-2, NFR-SEG-9	Ley 21.663; NCh 27002.Of2009
Integridad de documentos clínicos	RF-4.3, RF-4.4, NFR-SEG-3	Decreto 181; Ley 19.799
Trazabilidad y rendición de cuentas	RF-5.1, NFR-SEG-6	Ley 21.719; Ley 21.459
Disponibilidad del servicio	NFR-DIS-1, NFR-PERF-3	Ley 21.663
Accesibilidad e inclusión	NFR-USAB-1 a 4, NFR-COMPAT-2	Manual de Accesibilidad Web
Licenciamiento del software	Stack tecnológico, ERS §3.1.2	Ley 17.336, arts. 78 y 79

3. Plan de pruebas

3.1 Estrategia de pruebas

Enfoque general

Se adopta un enfoque mixto. Se automatizan las pruebas unitarias y de API, las verificaciones básicas de seguridad mediante análisis dinámico, las pruebas de rendimiento y la suite de humo. Se mantienen manuales las pruebas de usabilidad con adultos mayores, la exploración de flujos clínicos, la revisión de mensajes de error y la evaluación visual de criterios de accesibilidad.

La justificación es doble: la automatización reduce el costo de regresión sobre autenticación y API, que son las áreas de mayor riesgo legal y de cambio más frecuente; la ejecución manual resulta indispensable para validar la experiencia de usuarios mayores, criterio de aceptación explícito del ERS y dimensión que ninguna herramienta automatizada evalúa de forma concluyente.

Nota técnica de implementación (ambiente local)

Endpoints de referencia del backend Cuidarte+ utilizados en el diseño y ejecución de casos: POST /autenticacion/login y POST /autenticacion/registro; /usuarios; /pacientes; /examenes; /documentos; /auditoria; documentación OpenAPI en /docs. En el despliegue Docker local del repositorio, el frontend opera en el puerto 3333 y la API en el puerto 4444 (Swagger: http://localhost:4444/docs).

Etapas del proceso

Fase	Descripción	RF/NFR principales	Herramientas
1. Análisis y diseño	Revisión del ERS, análisis de riesgos y diseño de casos	Todos	ERS, matriz de trazabilidad
2. Pruebas unitarias	Validaciones, hashing y utilidades de autenticación	NFR-SEG-2, NFR-SEG-9	Jest
3. Integración de API	Contratos REST, códigos HTTP y manejo de JWT	RF-1 a RF-5, NFR-SEG-4	Postman, Swagger
4. Sistema y extremo a extremo	Flujos completos por rol en la interfaz React	RF-2 a RF-4, NFR-USAB-2	Ejecución manual con lista de verificación
5. Seguridad	RBAC, XSS, inyección SQL, TLS y gestión de sesión	NFR-SEG-1 a NFR-SEG-9	OWASP ZAP, Postman
6. Rendimiento	Carga y tiempos de respuesta	NFR-PERF-1 a NFR-PERF-3	k6, JMeter
7. Usabilidad y accesibilidad	Adultos mayores, contraste y comportamiento responsive	NFR-USAB, NFR-COMPAT	Lighthouse, sesiones UAT

Fase	Descripción	RF/NFR principales	Herramientas
8. Cierre	Informe de defectos, cobertura y criterios de terminado	Trazabilidad global	Matriz de trazabilidad

Priorización por riesgo

Prioridad	Área de riesgo	Motivo
P0	Autenticación, RBAC y documentos clínicos	Impacto legal directo y riesgo de filtración de datos de salud
P1	Auditoría y registros	Evidencia exigible ante incidentes conforme a las leyes 21.719 y 21.663
P2	CRUD de exámenes y pacientes	Núcleo funcional del negocio
P3	Rendimiento bajo carga	Umbrales comprometidos en el ERS
P4	Usabilidad y compatibilidad	Adopción por adultos mayores y uso multidispositivo

Criterios de entrada

ERS estable en la versión de referencia del caso semestral.

Ambiente de pruebas levantado mediante Docker, con frontend, backend y PostgreSQL operativos.

Usuarios de prueba creados por cada rol —administrador, médico y paciente— con datos anonimizados.

Casos de prueba diseñados y revisados por la dupla responsable.

Criterios de salida

Ejecución del 100% de los casos clasificados como P0 y P1.

Ausencia de hallazgos críticos de seguridad abiertos.

Cumplimiento del umbral NFR-PERF-1 en el ambiente de prueba.

Matriz de trazabilidad actualizada y brechas documentadas.

Informe de resultados disponible para los interesados.

3.2 Tipos de prueba

Distinción entre pruebas funcionales y no funcionales

Dimensión	Pruebas funcionales	Pruebas no funcionales
Pregunta central	¿El sistema hace lo que debe hacer?	¿Lo hace bien: de forma segura, rápida, usable y compatible?
Base de derivación	RF-1 a RF-5 y reglas de negocio	NFR-SEG, NFR-PERF, NFR-USAB, NFR-DIS y NFR-COMPAT
Ejemplo en Cuidarte+	El médico registra un examen a un paciente	La respuesta CRUD se mantiene bajo 300 ms; el paciente no puede eliminar usuarios

Ambas dimensiones son indispensables y no sustituibles entre sí. Un flujo funcionalmente correcto que filtre datos clínicos por un fallo de autorización no constituye un simple defecto de software: configura un incumplimiento de seguridad y de la legislación de protección de datos, con las consecuencias patrimoniales descritas en la sección 2.3.

Catálogo de tipos de prueba aplicables al caso

Tipo de prueba	Propósito	RF/NFR que cubre	Ejemplo en Cuidarte+
Funcionales	Verificar los comportamientos de negocio esperados	RF-1 a RF-5	Inicio de sesión, CRUD de exámenes, descarga de documentos
Integración y API	Validar los contratos entre React, Express y PostgreSQL	Interfaces §3.1.2, RF-1 a RF-4	Endpoint de autenticación y persistencia de la sesión
Seguridad	Detectar vulnerabilidades y fallas de control de acceso	NFR-SEG-1 a 9, RB-1 a RB-3	Un paciente invoca la API de administración y recibe 403; se rechaza una carga de inyección SQL
Usabilidad y accesibilidad	Asegurar el uso por adultos mayores y la claridad de los flujos	NFR-USAB-1 a 4	Contraste, botones táctiles y recorrido paciente a exámenes
Rendimiento y carga	Cumplir los umbrales de tiempo y concurrencia	NFR-PERF-1 a 3	CRUD bajo 300 ms con 200 usuarios concurrentes
Compatibilidad	Verificar navegadores y comportamiento responsive	NFR-COMPAT-1, NFR-COMPAT-2	Chrome, Firefox, Safari y Edge; móvil y tablet
Auditoría y cumplimiento	Verificar trazas y controles de origen legal	RF-5.1, NFR-SEG-6, NFR-SEG-8	Registro generado tras eliminar un usuario o descargar un documento
Humo	Validar la estabilidad mínima tras cada despliegue	RF críticos	Inicio de sesión, listado de pacientes y consulta de un examen
Regresión	Evitar que los cambios rompan funciones ya aceptadas	RF y NFR previamente aprobados	Reejecución de la suite tras corregir un hallazgo de seguridad

Justificación de la selección

Se priorizan las pruebas de seguridad, auditoría y usabilidad porque Cuidarte+ maneja datos sensibles de salud y se orienta a usuarios de edad avanzada. El rendimiento se incorpora porque el ERS fija umbrales cuantitativos verificables. La compatibilidad responde al carácter multidispositivo del producto. Cabe subrayar que las pruebas de cumplimiento normativo no se posponen al cierre del ciclo: se traducen desde el diseño en casos técnicos ejecutables, como la verificación de RBAC y la comprobación de registros de auditoría.

3.3 Criterios de aceptación

Un caso de prueba se considera aprobado únicamente si concurren las cuatro condiciones siguientes.

El resultado observado coincide con el resultado esperado documentado en el caso.

Se respeta la regla de negocio aplicable, según corresponda a RB-1, RB-2 o RB-3.

No se exponen datos clínicos a roles no autorizados en ningún punto del flujo.

Ante un fallo de seguridad o de cumplimiento normativo, el caso se marca como fallido aunque la interfaz presente un comportamiento aparentemente correcto.

Este último criterio es deliberado: en un sistema que trata datos de salud, la corrección visual no acredita conformidad. La verificación se realiza sobre la respuesta del backend y sobre el registro de auditoría, no sobre lo que muestra la pantalla.

3.4 Herramientas y recursos necesarios

Recursos humanos

Rol	Responsabilidad
Analista de pruebas	Diseño y ejecución de casos; registro y seguimiento de defectos
Desarrollador backend	Soporte de la API, generación de datos de prueba y corrección de hallazgos
Desarrollador frontend	Soporte de interfaz, comportamiento responsive y accesibilidad
Responsable de seguridad	Lista de verificación OWASP, revisión de RBAC y de registros de auditoría
Usuario representativo (adulto mayor)	Sesiones de usabilidad; mínimo de cinco participantes según el ERS §3.1.1
Coordinación del plan	Trazabilidad, revisión normativa y entrega formal del informe

Recursos técnicos

Recurso	Uso previsto
Node.js 18 o superior, React 19, Express, PostgreSQL 15	Stack tecnológico del producto
Docker Compose	Entorno reproducible con base de datos, backend y frontend
Postman y Swagger	Pruebas de API e integración
Jest	Pruebas unitarias
OWASP ZAP	Análisis dinámico de seguridad: XSS, cabeceras y rutas expuestas
Lighthouse	Accesibilidad y rendimiento del frontend
k6 o JMeter	Pruebas de carga y verificación de umbrales NFR-PERF
Chrome, Firefox, Edge y Safari	Matriz de compatibilidad de navegadores
Conjunto de datos anonimizados o sintéticos	Cumplimiento del principio de minimización; se excluyen RUT y datos reales de pacientes

Entorno de prueba

Ambiente	Propósito
Local sobre Docker	Desarrollo y ejecución diaria de la suite de humo
QA o staging	Ejecución formal de la suite completa, con TLS habilitado y roles de prueba creados

Las cuentas de prueba sugeridas son ficticias —admin.qa, medico.qa y paciente.qa— y sus contraseñas cumplen la política del ERS de al menos doce caracteres con mayúscula, minúscula, número y símbolo. El uso exclusivo de datos sintéticos durante las pruebas no es una comodidad técnica sino una exigencia derivada del principio de minimización de la Ley 21.719.

Cronograma de ejecución

Semana	Actividades	Entregables
Semana 1	Análisis del ERS, evaluación de riesgos, diseño de casos P0 y P1, preparación del ambiente	Casos CP-01 a CP-06; entorno QA operativo
Semana 2	Ejecución funcional, integración de API, pruebas de seguridad y auditoría	Bitácora de defectos; resultados de CP-01 a CP-04
Semana 3	Rendimiento, usabilidad y compatibilidad, regresión y cierre	Resultados de CP-05 y CP-06; matriz de cobertura; informe final

Estimación de esfuerzo

Tipo de prueba	Esfuerzo relativo
Funcional y auditoría	30%
Seguridad	25%
Usabilidad y compatibilidad	20%
Rendimiento	15%
Coordinación, trazabilidad y reporte	10%

4. Diseño de casos de prueba

Se diseñan seis casos representativos que cubren los distintos tipos de requerimiento definidos en el ERS. Cada caso se documenta con el identificador, el nombre, el requerimiento asociado, la descripción, las precondiciones, los pasos de ejecución, el resultado esperado, el criterio de aceptación y los datos de prueba, conforme al formato institucional.

CP-01 — Autenticación válida y rechazo de credenciales inválidas

ID	NOMBRE	REQUERIMIENTO
CP-01	Autenticación válida y rechazo de credenciales inválidas	**RF-1.1:** El sistema debe permitir a un usuario autenticarse con nombre_usuario y contraseña. **NFR-SEG-9:** Manejo de sesión mediante token de acceso (JWT).
DESCRIPCIÓN		
Verificar que un usuario válido obtiene una sesión JWT y que las credenciales inválidas son rechazadas sin exponer información sensible ni revelar la existencia de la cuenta.		
PRECONDICIONES		
Backend y base de datos levantados en el ambiente QA. Usuario medico.qa creado con rol médico y contraseña conforme a la política del ERS.		
PASOS		
1.Enviar POST al endpoint de autenticación con credenciales válidas. 2.Verificar la presencia del token JWT en la respuesta y su tiempo de expiración. 3.Enviar POST al mismo endpoint con contraseña incorrecta. 4.Verificar el código de respuesta y la ausencia de token. 5.Revisar los registros del servidor para confirmar que no se almacena la contraseña. Rutas reales de referencia: POST /autenticacion/login (API http://localhost:4444).		
RESULTADO ESPERADO		
El inicio de sesión válido devuelve HTTP 200 junto con un token JWT de vigencia acotada. El inicio de sesión inválido devuelve HTTP 401, sin token y con un mensaje de error genérico.		
CRITERIO DE ACEPTACIÓN		
El acceso exitoso genera un token de sesión. El fallo no revela si el usuario existe. No se registran contraseñas ni tokens en los registros del sistema.		
DATOS DE PRUEBA		
Usuario válido: medico.qa / PruebaSegura#2026. Usuario inválido: medico.qa / ClaveIncorrecta#1		
TIPO DE PRUEBA		
Funcional y de seguridad		

CP-02 — Registro de examen médico por un profesional autorizado

ID	NOMBRE	REQUERIMIENTO

CP-02	Registro de examen médico por un profesional autorizado	**RF-3.1:** Un usuario médico puede registrar un nuevo examen a un paciente para llevar registro de sus antecedentes médicos. **RB-3:** Un médico puede ver la información clínica de cualquier paciente registrado.
DESCRIPCIÓN		
Validar que un médico autenticado puede crear un examen asociado a un paciente existente y que el sistema valida correctamente los campos obligatorios.		
PRECONDICIONES		
Sesión activa de médico. Paciente de prueba previamente registrado en el sistema.		
PASOS		
1. Iniciar sesión con el rol médico. 2. Seleccionar el paciente de prueba. 3. Registrar un examen con datos válidos y adjuntar un documento PDF dentro del límite permitido. 4. Confirmar la persistencia del registro en el listado y en el detalle. 5. Intentar guardar un examen sin los campos obligatorios y verificar el rechazo. Rutas reales: POST /autenticacion/login; GET /pacientes; GET /tipo-examen; POST /examenes; verificación con GET /examenes/:id o GET /examenes/paciente/:paciente_id. Adjunto vía /documentos cuando corresponda.		
RESULTADO ESPERADO		
El examen se crea y el sistema devuelve HTTP 201. El registro queda visible para el médico y correctamente asociado al paciente. El intento sin campos obligatorios es rechazado con un mensaje comprensible.		
CRITERIO DE ACEPTACIÓN		
El CRUD de exámenes opera conforme a lo especificado, la validación de ingreso funciona en el servidor y el médico accede a la información clínica del paciente según RB-3.		
DATOS DE PRUEBA		
Identificador del paciente de prueba; tipo de examen: hemograma completo; fecha de emisión; observaciones: control rutinario; documento PDF adjunto.		
TIPO DE PRUEBA		
Funcional		

CP-03 — Registro de auditoría ante una acción crítica

ID	NOMBRE	REQUERIMIENTO
CP-03	Registro de auditoría ante una acción crítica	**RF-5.1:** Registrar en auditoría las acciones críticas: creación, edición y eliminación de registros, y subida o descarga de documentos. **NFR-SEG-6:** Gestión de log segura.
DESCRIPCIÓN		
Comprobar que la eliminación de un examen o de un usuario genera un registro de auditoría que identifica al actor, la acción, la fecha y el recurso afectado.		
PRECONDICIONES		
Examen existente creado en CP-02. Usuario con rol autorizado para ejecutar la eliminación.		
PASOS		

1. Ejecutar la eliminación previa confirmación en la interfaz. 2. Consultar el módulo o la tabla de auditoría. 3. Verificar los campos mínimos del evento registrado. 4. Confirmar que no se auditan contraseñas ni tokens de sesión. Rutas reales: DELETE /examenes/:id (o DELETE /usuarios/:id según rol); consulta GET /auditoria.
RESULTADO ESPERADO
Tras confirmar la eliminación, existe un registro de auditoría que consigna la acción, el usuario responsable, la marca temporal y la referencia al recurso afectado.
CRITERIO DE ACEPTACIÓN
Se genera un registro por cada acción crítica y la interfaz solicita confirmación antes de eliminar. El registro no contiene datos secretos.
DATOS DE PRUEBA
Identificador del examen creado en CP-02; usuario actor medico.qa, o admin.qa si se prueba la baja de un usuario.
TIPO DE PRUEBA
Funcional y de cumplimiento

CP-04 — Control de acceso por rol y resistencia a inyección

ID	NOMBRE	REQUERIMIENTO
CP-04	Control de acceso por rol y resistencia a inyección	**NFR-SEG-4:** Control de acceso por rol en backend. **NFR-SEG-5:** Protección contra CSRF, XSS e inyección SQL; validación y saneamiento de entrada. **RB-1:** Un paciente solo tiene permisos de lectura.
DESCRIPCIÓN		
Verificar que un paciente no puede ejecutar operaciones de administración ni modificar datos ajenos, y que las entradas maliciosas de inyección SQL y XSS son rechazadas o saneadas.		
PRECONDICIONES		
Usuarios de los tres roles disponibles. Endpoints protegidos y desplegados en el ambiente QA.		
PASOS		
1.Autenticarse con el rol paciente y obtener el token. 2.Invocar un endpoint reservado a la administración de usuarios. 3.Intentar editar o eliminar un examen que no pertenece al paciente. 4.Enviar cargas de inyección SQL y XSS en los campos de entrada. 5.Registrar los códigos HTTP obtenidos y el comportamiento de la interfaz. Rutas reales: con token de paciente invocar GET /usuarios y/o DELETE /usuarios/:id (esperado 401/403); control positivo con token médico sobre GET /examenes/paciente/:id. Evidencia exploratoria sep-2026: paciente→GET /usuarios→403; login SQLi→401 sin JWT.		
RESULTADO ESPERADO		
Los accesos indebidos devuelven HTTP 401 o 403. La inyección SQL no autentica ni altera las consultas. El script XSS no se ejecuta, sino que se escapa o sanea. El paciente conserva únicamente lectura sobre sus propios exámenes.		
CRITERIO DE ACEPTACIÓN		
El control de acceso es efectivo en el backend y no solo en la interfaz. Las entradas se validan y sanean. No se registran hallazgos críticos de inyección en la lista de verificación de seguridad.		

DATOS DE PRUEBA
Token de paciente.qa. Carga de autenticación: ' OR 1=1 --. Carga en el campo de observaciones: <script>alert(1)</script>
TIPO DE PRUEBA
No funcional — Seguridad

CP-05 — Tiempo de respuesta de operaciones CRUD bajo carga normal

ID	NOMBRE	REQUERIMIENTO
CP-05	Tiempo de respuesta de operaciones CRUD bajo carga normal	**NFR-PERF-1:** Tiempo de respuesta para operaciones CRUD simples menor a 300 ms bajo carga normal.
DESCRIPCIÓN		
Medir el tiempo de respuesta de las operaciones CRUD de pacientes y exámenes bajo carga normal y contrastarlo con el umbral comprometido en el ERS.		
PRECONDICIONES		
Ambiente QA estable con el conjunto de datos sintéticos cargado y sin otras pruebas en ejecución. Aviso técnico del repositorio: varias rutas (/examenes, /pacientes, /documentos) usan delayMiddleware(5000) en desarrollo; la medición formal de NFR-PERF-1 debe ejecutarse sin ese delay, o documentarse explícitamente como limitación del ambiente.		
PASOS Resultado ejecutado con delay artificial activo: 220 samples, 0% error; login p95 ≈ 14 ms (cumple); GET /pacientes y GET /examenes p95 ≈ 5008–5011 ms (no cumple NFR-PERF-1). Ver Anexos/jmeter/Informe_JMeter_CP05.md.		
1.Preparar la colección de peticiones CRUD representativas. 2.Ejecutar la prueba de carga durante cinco minutos. 3.Comparar el percentil 95 con el umbral de 300 ms. 4.Documentar las desviaciones y los recursos consumidos. Artefacto ejecutable del equipo: Anexos/jmeter/CuidartePlus_CP05.jmx (TG-A 20 VUs; TG-B 50 VUs smoke de concurrencia).		
RESULTADO ESPERADO		
El percentil de respuesta de las operaciones CRUD simples se mantiene bajo 300 ms durante toda la ventana de carga normal.		
CRITERIO DE ACEPTACIÓN		
La prueba cumple el umbral NFR-PERF-1 y se adjunta el resumen de latencias con su gráfico correspondiente.		
DATOS DE PRUEBA		
Script k6 o JMeter con 20 usuarios virtuales ejecutando operaciones GET y POST sobre exámenes y pacientes durante cinco minutos.		
TIPO DE PRUEBA		
No funcional — Rendimiento		

CP-06 — Usabilidad para adulto mayor y compatibilidad responsive

ID	NOMBRE	REQUERIMIENTO

CP-06	Usabilidad para adulto mayor y compatibilidad responsive	**NFR-USAB-1:** Interfaces con tipografía legible, contraste adecuado y controles grandes para usuarios mayores. **NFR-USAB-2:** Flujos claros para registro y visualización de exámenes o documentos. **NFR-USAB-4:** El flujo de acceso a la información debe escalar: primero se accede al paciente y luego a sus exámenes médicos. **NFR-COMPAT-2:** Responsivo para móviles y tablets.
DESCRIPCIÓN		
Evaluar que un paciente adulto mayor pueda completar el flujo de acceso a su información clínica en móvil y tablet, con tipografía legible, contraste adecuado y controles táctiles suficientes.		
PRECONDICIONES		
Frontend desplegado. Cuenta de paciente con al menos un examen y un documento asociado.		
PASOS		
1.Abrir la aplicación en un dispositivo móvil con viewport de 375 px. 2.Iniciar sesión con el rol paciente. 3.Navegar desde el perfil al listado de exámenes, al detalle y a la descarga del documento. 4.Verificar contraste, tamaño de fuente y dimensión de los controles. 5.Repetir la prueba de humo en tablet y en un navegador alternativo. Ambiente de referencia: frontend http://localhost:3333.		
RESULTADO ESPERADO		
El flujo se completa sin bloqueos mayores. La interfaz responde correctamente al viewport, los textos resultan legibles, los controles son alcanzables y los mensajes de error son comprensibles.		
CRITERIO DE ACEPTACIÓN		
La sesión con usuario representativo concluye sin bloqueos mayores, se cumplen los criterios básicos de accesibilidad y se alcanza el puntaje mínimo de la lista de verificación del equipo.		
DATOS DE PRUEBA		
Dispositivo móvil con viewport de 375 px y tablet; usuario paciente.qa; lista de verificación de contraste y tamaño mínimo de controles.		
TIPO DE PRUEBA		
No funcional — Usabilidad y compatibilidad		

5. Análisis de cobertura, pertinencia y coherencia

5.1 Matriz de trazabilidad

La matriz siguiente permite verificar que cada requerimiento relevante del ERS tiene al menos un caso de prueba asociado y, a la inversa, que ningún caso diseñado carece de fundamento en el ERS.

Requerimiento o regla	Tipo de prueba	Caso asociado	Cobertura
RF-1.1	Funcional y de seguridad	CP-01	Cubierto
RF-1.2	Seguridad de sesión	CP-01	Parcial
RF-3.1	Funcional	CP-02	Cubierto
RB-3	Funcional	CP-02	Cubierto
RF-5.1	Auditoría	CP-03	Cubierto
NFR-SEG-4 y RB-1	Seguridad	CP-04	Cubierto
NFR-SEG-5	Seguridad	CP-04	Cubierto
NFR-PERF-1	Rendimiento	CP-05	Cubierto
NFR-USAB-1, 2 y 4	Usabilidad	CP-06	Cubierto
NFR-COMPAT-2	Compatibilidad	CP-06	Cubierto
NFR-SEG-8	Cumplimiento vía RBAC y auditoría	CP-03, CP-04	Cubierto de forma indirecta

5.2 Brechas identificadas y priorización

El reconocimiento explícito de las brechas es parte de la evaluación de cobertura. Se documentan a continuación aquellas que este ciclo no alcanza a cubrir, junto con la justificación de su postergación.

Brecha	Justificación y siguiente iteración	Prioridad
RF-2, CRUD completo de usuarios por el administrador	Cubierto conceptualmente por la verificación de RBAC; se recomienda incorporar un caso CP-07 en el segundo ciclo	Media
RF-4.2, descarga de documentos con umbral de diez segundos	Cubierto parcialmente en CP-06; corresponde medir el tiempo de forma explícita en el segundo ciclo	Media
NFR-PERF-2 y NFR-PERF-3	Solo se midió NFR-PERF-1 en CP-05 por el foco acotado de esta evaluación	Media
NFR-SEG-1 sobre TLS y NFR-SEG-7 sobre respaldos	Verificables mediante lista de comprobación del entorno; no constituyen casos de interfaz	Alta como control operativo
NFR-DIS-1, disponibilidad de 99,5%	Requiere monitoreo prolongado, fuera del alcance temporal de esta evaluación	Baja en este ciclo

La priorización privilegia deliberadamente el riesgo legal y clínico —autenticación, control de acceso, auditoría e integridad documental— por sobre las métricas de comportamiento a largo plazo. Un fallo en las primeras genera responsabilidad patrimonial inmediata conforme al artículo 35 de la Ley 21.719; un incumplimiento de las segundas genera, en cambio, una degradación de servicio corregible en iteraciones posteriores.

5.3 Coherencia entre estrategia, recursos y cronograma

La estrategia mixta es sostenible con las herramientas efectivamente disponibles en el taller —Postman, Docker, Lighthouse y k6— y con las sesiones manuales de usabilidad, sin requerir licencias ni infraestructura adicional.

El cronograma de tres semanas concentra los casos P0 y P1 en la semana dos, lo que resulta coherente con la priorización por riesgo declarada en la sección 3.1.

Los seis casos diseñados materializan tanto los tipos funcionales como los no funcionales exigidos, cubriendo autenticación, funcionalidad clínica, auditoría, seguridad, rendimiento y usabilidad.

La sección normativa conecta el requerimiento NFR-SEG-8 con normas chilenas concretas y con artículos determinados, evitando las menciones genéricas que no admiten verificación.

5.4 Evaluación frente a los indicadores de la rúbrica

Indicador	Evidencia en este informe
IE1	Sección 2: criterios de calidad y seguridad junto al marco legal chileno aplicado al dominio clínico
IE2	Sección 3.2: clasificación y justificación de los tipos de prueba, con distinción explícita entre funcionales y no funcionales
IE3	Casos CP-04, CP-05 y CP-06: pruebas no funcionales con criterios de aceptación medibles
IE4	Secciones 1, 3.1 y 3.4: introducción, estrategia, recursos, cronograma y vínculo con el ERS y las normas
IE5	Sección 5: matriz de trazabilidad, brechas priorizadas, coherencia y recomendaciones

6. Conclusiones y recomendaciones

El plan de pruebas diseñado para Cuidarte+ integra calidad, seguridad y cumplimiento normativo desde la etapa de diseño, en alineación con el ERS del caso semestral. Los seis casos representativos cubren autenticación, funcionalidad clínica, auditoría, control de acceso y saneamiento de entradas, rendimiento y usabilidad con compatibilidad.

La conclusión central del análisis es que, tratándose de un sistema que administra datos sensibles de salud, la separación tradicional entre defecto funcional e incumplimiento legal deja de ser útil. Una

autorización mal implementada no es un error de programación con consecuencias técnicas: es un tratamiento indebido de datos sensibles, con las sanciones que el artículo 35 de la Ley 21.719 asocia a las infracciones graves y gravísimas. Por esa razón el plan traduce cada exigencia normativa en un criterio de aceptación observable y no en una declaración de intenciones.

Recomendaciones

Ampliar la suite con casos de cierre de sesión y revocación de token (RF-1.2) y de CRUD administrativo (RF-2.5 a RF-2.7).

Medir el rendimiento con delayMiddleware desactivado y reutilizar el plan JMeter de Anexos/jmeter/CuidartePlus_CP05.jmx para verificar NFR-PERF-1 en condiciones reales de QA.

Formalizar una lista de comprobación de TLS y respaldos (NFR-SEG-1 y NFR-SEG-7) aplicable a cada despliegue en QA.

Ejecutar al menos una sesión de aceptación con cinco adultos mayores, documentando los hallazgos conforme al ERS §3.1.1.

Mantener el uso exclusivo de datos de prueba sintéticos, reduciendo el riesgo legal durante la ejecución del ciclo.

Incorporar, antes del paso a producción, un análisis dinámico de mayor profundidad y una revisión de dependencias que verifique tanto vulnerabilidades conocidas como compatibilidad de licencias, conforme a los artículos 78 y 79 de la Ley 17.336.

Incorporar un mecanismo de verificación de integridad —resumen criptográfico almacenado y revalidado en cada descarga— sobre los documentos clínicos, en cumplimiento del Título Cuarto del Decreto 181.

7. Referencias

Chile. Ley N° 17.336, sobre propiedad intelectual, de 2 de octubre de 1970.

Chile. Ley N° 19.628, sobre protección de la vida privada, de 28 de agosto de 1999.

Chile. Ley N° 19.799, sobre documentos electrónicos, firma electrónica y servicios de certificación.

Chile. Decreto Supremo N° 181, de 17 de agosto de 2002, reglamento de la Ley N° 19.799.

Chile. Ley N° 21.180, sobre transformación digital del Estado, de 11 de noviembre de 2019.

Chile. Ley N° 21.459, que establece normas sobre delitos informáticos, de 20 de junio de 2022.

Chile. Ley N° 21.663, Ley Marco sobre Ciberseguridad e Infraestructura Crítica de la Información.

Chile. Ley N° 21.719, que regula la protección y el tratamiento de los datos personales.

Chile. Política Nacional de Ciberseguridad.

Instituto Nacional de Normalización. NCh 27002.Of2009, Tecnología de la información: código de práctica para la gestión de la seguridad de la información.

Gobierno de Chile. Manual de Accesibilidad Web.

ISO/IEC 25010, Systems and software Quality Requirements and Evaluation (SQuaRE): modelos de calidad.

OWASP Foundation. OWASP Top 10: riesgos de seguridad en aplicaciones web.

DuocUC. EP1_ISY1102_Estudiante: instrucciones y pauta de evaluación.

DuocUC. EP1_ISY1102_Estudiante_ERS_B: especificación de requerimientos de software del sistema Cuidarte+.